

Módulo 3: Identidad y Control de Acceso

T07: Autenticación Rota y JWT

Carlos Rodríguez Contreras · GitHub: karrocon

🔒 *JWT mal configurado, fuerza bruta y el ataque* `alg: none`

Objetivos

- Entender la estructura de un JWT (header, payload, signature)
- Explotar el algoritmo `alg: none` en VulnApp para falsificar tokens
- Ejecutar un ataque de fuerza bruta a un JWT con clave débil
- Configurar JWT correctamente (clave fuerte, RS256, expiración corta)

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.



Lab T07: Falsificando un JWT

Objetivo: modificar el payload de un JWT para escalar privilegios

Setup: `cd VulnApp && npm start`

1. Inicia sesión y copia el token JWT de la respuesta
2. Decodifícalo en jwt.io y observa el payload
3. Cambia `"role": "user"` a `"role": "admin"` y usa `alg: none`
4. Repite la petición con el token modificado — ¿funciona?
5. Corrige `src/middleware/auth.ts` para rechazar `alg: none`